

Legal & Ethical Implementation

Legal Obligations Matrix, Applied Ethical Framework, Compliance Risk Assessment & Incident Scenario

Scenario organization: Horizon Valley Medical Center (HVMC)

Capstone project: AccessGuard Health — Azure/Entra ID & AWS IAM Operations

Rubric item: Legal & Ethical Implementation

Builds on: Compliance Auditing Basics and Documentation & Reporting submissions (HIPAA Security Rule Technical Safeguards)

Report date: October 6, 2026

Created by: Sabitha S Karanavar

This submission is prepared as a classroom lab exercise for the HVMC simulation used in this capstone. The legal citations are to real, current HIPAA/HITECH authority; the ethical scenario, risk register, and incident scenario are illustrative/simulated against the lab's AD/Entra ID/AWS IAM environment and do not describe an actual event. Nothing here is legal advice.

Rubric Cross-Reference

Rubric Requirement	Where Addressed
Research and document legal requirements using proper sources with compliance obligations matrix and regulatory citations	Section 1 — Legal Requirements & Compliance Obligations Matrix
Apply ethical framework to compliance scenario including decision-making process and rationale documentation	Section 2 — Applied Ethical Framework
Conduct compliance risk assessment using standard methodology with risk identification, impact analysis, and treatment recommendations	Section 3 — Compliance Risk Assessment
Document one compliance incident scenario using standard procedures including classification, reporting, and follow-up actions	Section 4 — Compliance Incident Scenario

1. Legal Requirements & Compliance Obligations Matrix

1.1 Sources Consulted

- U.S. Department of Health & Human Services, Office for Civil Rights — *HIPAA for Professionals* (hhs.gov/hipaa)
- Electronic Code of Federal Regulations, Title 45, Parts 160 and 164 ([ecfr.gov](https://www.ecfr.gov)) — the current, codified text of the Privacy, Security, and Breach Notification Rules
- Health Information Technology for Economic and Clinical Health (HITECH) Act, Pub. L. 111-5, Title XIII (2009), codified in part at 42 U.S.C. §17921 et seq.
- HIPAA Journal, *HIPAA Compliance Checklist* — the program reference document used across this capstone's compliance deliverables

1.2 Compliance Obligations Matrix

Obligation	Legal Source & Citation	HVMC Control / Process Satisfying It
Minimum necessary disclosure of PHI	HIPAA Privacy Rule — 45 CFR §164.502(b), §164.514(d)	Least-privilege IAM roles across AD, Entra ID, and AWS IAM, assigned through the JML lifecycle (Activities 1–5)

Unique identification of every user accessing ePHI	HIPAA Security Rule — 45 CFR §164.312(a)(2)(i)	Unique AD/Entra ID/AWS IAM accounts, verified in the Compliance Auditing Basics audit (Control 1)
Audit controls / activity logging	HIPAA Security Rule — 45 CFR §164.312(b)	CloudTrail, VPC Flow Logs, GuardDuty, and Samba4 authentication logging (Control 2)
Emergency access procedure for ePHI	HIPAA Security Rule — 45 CFR §164.312(a)(2)(ii)	Break-glass emergency access procedure, developed in Section 2 below
Workforce security awareness and training	HIPAA Security Rule — 45 CFR §164.308(a)(5)	HIPAA training plan (Compliance Program Development deliverable)
Business Associate Agreements with vendors	HIPAA Security Rule — 45 CFR §164.308(b)(1), §164.314(a)	Vendor BAA tracking procedure, checked during onboarding of any third-party vendor
Patient right of access to their own records within 30 days	HIPAA Privacy Rule — 45 CFR §164.524	Documented patient access-request procedure
Breach risk assessment and notification	HIPAA Breach Notification Rule — 45 CFR §164.402, §§164.404–164.408	Incident classification and reporting procedure, Section 4 below
Civil monetary penalty exposure and OCR enforcement	HITECH Act, Pub. L. 111-5, Title XIII (2009); 45 CFR §160.401–160.426	Risk register treatment priority, Section 3 below

2. Applied Ethical Framework

2.1 Framework Selected: Principlism

This analysis applies **principlism**, the four-principle bioethics framework (Beauchamp & Childress) widely used in healthcare ethics: **autonomy** (respecting a patient's right to control their own information and care), **beneficence** (acting to benefit the patient), **non-maleficence** (avoiding harm), and **justice** (applying rules fairly and consistently). It is well suited to IAM decisions in a healthcare setting because access control, by design, exists to balance exactly these four principles against each other.

2.2 Compliance Scenario

Scenario: Break-Glass Emergency Access Request

During an after-hours code-blue event, an on-call physician who is not assigned to the patient's care team needs immediate access to the patient's chart to review medication allergies and recent lab results. The physician's standard AD/Entra ID role does not include this patient under least-privilege/minimum-necessary access rules, and there is no time to route a normal access request through the IAM/Identity Administrator.

2.3 Decision-Making Process

- 1 Identify the facts** — a non-assigned physician needs emergency, time-critical access to one patient's ePHI; the standard access-request workflow cannot complete in time.
- 2 Identify stakeholders** — the patient, the treating/requesting physician, HVMC (legal and reputational exposure), and the compliance program (audit integrity).
- 3 Apply the four principles** — *Beneficence* and *non-maleficence* favor granting access immediately, since delay risks patient harm. *Autonomy* is preserved because emergency treatment access is a reasonably expected use of a patient's own record under HIPAA's treatment-purpose exception. *Justice* requires that this exception not become an unaudited backdoor available to anyone who claims urgency.
- 4 Identify options** — (a) deny access and route through the standard request process; (b) grant silent, unlogged override access; (c) grant immediate "break-glass" access gated by a mandatory justification and automatic post-access audit review.
- 5 Evaluate against the principles** — Option (a) fails beneficence/non-maleficence (patient harm from delay). Option (b) fails justice (unaccountable exception) and the Security Rule's audit-control requirement. Option (c) satisfies beneficence and non-maleficence by granting timely access, and satisfies justice and autonomy by keeping the exception bounded, justified, and reviewed.
- 6 Decide and document the rationale** — HVMC grants break-glass access under Option (c): the physician enters a brief reason code at the point of access, the system logs the override event to the same audit trail as all other ePHI access (Control 2), and the Compliance Auditor reviews every break-glass event within 5 business days.

- 7 Build in accountability** — the emergency access procedure is formally documented to satisfy 45 CFR §164.312(a)(2)(ii) (Section 1.2), and every use is carried into the risk register (R4, Section 3) and the quarterly compliance status report.

Rationale summary: the decision privileges patient welfare in a genuine emergency while keeping the exception auditable and bounded, so that the fairness (justice) owed to the broader population of patients whose minimum-necessary protections depend on this not becoming routine is preserved.

3. Compliance Risk Assessment

3.1 Methodology

This assessment follows the qualitative risk-assessment methodology in **NIST SP 800-30 Rev. 1, *Guide for Conducting Risk Assessments***: for each risk, likelihood and impact are each rated Low/Medium/High, the two are combined into an overall risk level, and a treatment option (Mitigate, Avoid, Transfer, or Accept) is assigned. Risks are drawn from the findings already documented in the Compliance Auditing Basics and Documentation & Reporting submissions, plus the ethical scenario in Section 2, so the risk register reflects this capstone's actual audit evidence rather than a generic list.

3.2 Risk Identification, Impact Analysis & Treatment

ID	Risk	Likelihood	Impact	Risk Level	Treatment Recommendation
R1	Unauthorized use of an orphaned/unmanaged IAM account	Medium	High	HIGH	Mitigate — assign an individual owner or deprovision immediately; add automated orphaned-account detection (already in progress per the audit remediation plan)
R2	Insufficient log retention impedes a future breach investigation	Medium	High	HIGH	Mitigate — configure the 6-year HIPAA-aligned retention policy on CloudTrail/GuardDuty/domain logs
R3	Workforce members unaware of the login/logout procedure	Medium	Medium	MEDIUM	Mitigate — distribute the procedure and collect signed acknowledgments through the workforce portal
R4	Break-glass emergency access used without adequate audit trail	Low	High	MEDIUM	Mitigate — enforce mandatory justification entry and a 5-business-day Compliance Auditor review of every event
R5	A business associate vendor operating without an executed BAA	Low	High	MEDIUM	Mitigate — make BAA execution a hard gate in vendor onboarding; audit existing vendor list annually
R6	Unauthorized "snooping" access to a high-profile patient's record	Low	High	MEDIUM	Mitigate — enable anomaly detection on access logs for high-profile patient flags and enforce the workforce sanction policy on confirmed snooping

Impact analysis note: impact ratings reflect three compounding factors for a healthcare organization: regulatory exposure (HIPAA civil monetary penalties under the HITECH-amended tiered structure, 45 CFR §160.404), patient

harm and loss of trust, and the operational cost of breach notification and remediation. Risks R1 and R2 are rated High because each would directly expand the scope or delay the investigation of an actual breach; R3–R6 are rated Medium because each represents a real but currently bounded or low-likelihood exposure.

4. Compliance Incident Scenario

The scenario below is a simulated/hypothetical tabletop exercise built from Risk R1 (Section 3), illustrating how HVMC's standard incident procedure would classify, report, and follow up on that risk if it materialized. No actual incident occurred.

Simulated Incident: Unauthorized Access via an Orphaned AWS IAM Account

CloudTrail and GuardDuty generate an alert for anomalous API activity under the legacy AWS IAM account identified without an individual owner during the Compliance Auditing Basics audit. The activity occurs outside normal business hours and includes read/download actions against an S3 bucket holding de-identified-adjacent patient data exports used for reporting.

4.1 Classification

1. **Detection & triage:** the security dashboard (Week 7 logging/monitoring build) flags the event; the Incident Response team opens a case under the Cloud IR Playbook and classifies it as a Security Incident pending a breach risk assessment.
2. **Breach risk assessment** (45 CFR §164.402, the four-factor test):
 - *Nature and extent of the PHI/ePHI-adjacent data involved* — reporting-export fields with patient identifiers and dates of service.
 - *Unauthorized person who used or received it* — unknown; the account had no assigned individual owner at the time of the activity.
 - *Whether the data was actually acquired or viewed* — CloudTrail data-access logging confirms download (GetObject) events, so acquisition is presumed.
 - *Extent to which the risk has been mitigated* — the account was disabled and credentials rotated within one hour of the alert.
3. **Conclusion:** the presumption of breach under the Breach Notification Rule is not rebutted on these facts; the incident is classified as a **Reportable Breach** affecting a simulated count of fewer than 500 individuals for this exercise.

4.2 Reporting

- **Internal:** the Compliance Officer and IR team are notified within 1 hour per the IR Playbook's escalation path; the finding is linked back to remediation item R1 in the risk register.
- **Affected individuals:** notified without unreasonable delay and no later than 60 days after discovery, per 45 CFR §164.404.
- **Regulators:** because the simulated count is under 500, the breach is logged for HVMC's annual summary notification to OCR (due within 60 days of the end of the calendar year in which it was discovered) per 45 CFR §164.408, rather than the immediate OCR report and media notice required at the 500-or-more threshold.

4.3 Follow-Up Actions

- Deprovision or reassign every legacy/unowned credential across AD, Entra ID, and AWS IAM (closes R1).
- Stand up automated orphaned-account detection so an unowned account cannot persist undetected for this long again.
- Confirm the log-retention fix from R2 is in place, since it is what let the investigation reconstruct the download activity in the first place.
- Record the incident and its closure in the remediation tracker and carry a lessons-learned summary into the next quarterly compliance status report.

Sources: HHS Office for Civil Rights (hhs.gov/hipaa); eCFR Title 45, Parts 160 & 164; HITECH Act, Pub. L. 111-5; HIPAA Journal, HIPAA Compliance Checklist. Prepared as the Legal & Ethical Implementation deliverable for the Semester 4 Healthcare IAM Operations Home Lab capstone.